

TechCorp - Information Security Master Policy

Document Version: 3.0

Framework: NCA ECC-1:2018

Cybersecurity Governance (NCA-ECC Subdomain 1-1) .1

1.1. Cybersecurity Strategy and Leadership

TechCorp is committed to protecting its information assets in alignment with the regulatory requirements of the Kingdom of Saudi Arabia, specifically the National Cybersecurity Authority (NCA) Essential Cybersecurity Controls. The Board of Directors has formally appointed a Chief Information Security Officer (CISO) who holds ultimate responsibility for executing the cybersecurity strategy. The CISO reports directly to the CEO, ensuring the independence of the cybersecurity function from IT operations.

1.2. Cybersecurity Policies and Procedures

All employees, contractors, and third-party vendors must adhere to this Information Security Policy. The policy is reviewed annually or following any significant change to the IT environment. Violations of this policy will result in disciplinary action, up to and including termination.

1.3. Cybersecurity Risk Management (NCA-ECC Subdomain 1-3)

TechCorp conducts comprehensive cybersecurity risk assessments annually and prior to the deployment of any new critical system. Risks are identified, quantified, and treated using a formal risk register. Acceptable risk levels are defined by the Board. All systems processing sensitive data must undergo a rigorous security architecture review.

Cybersecurity Defense (NCA-ECC Subdomain 2-1 to 2-8) .2

2.1. Identity and Access Management (IAM)

Access to TechCorp systems follows the Principle of Least Privilege (PoLP) and Role-Based Access Control (RBAC).

Authentication: Multi-Factor Authentication (MFA) is strictly enforced for all external access, remote access (VPN), and privileged administrative accounts. •

Password Policy: Passwords must be at least 14 characters, require complexity, and be rotated every 90 days. •

Privileged Access: Administrative sessions are recorded and monitored using a Privileged Access Management (PAM) solution. Unused accounts are automatically disabled after 30 days of inactivity. •

2.2. Network Security

The TechCorp network is logically segregated using firewalls and VLANs.

- A Demilitarized Zone (DMZ) is established to host all external-facing services.
- Intrusion Prevention Systems (IPS) and Intrusion Detection Systems (IDS) are deployed at all network boundaries.
- All data transmitted over public networks is encrypted using TLS 1.2 or higher.

2.3. Endpoint and Mobile Device Security

All corporate-issued workstations and servers are equipped with Endpoint Detection and Response (EDR) solutions. USB mass storage devices are strictly blocked via Group Policy. Mobile devices accessing corporate data are managed via a Mobile Device Management (MDM) solution that enforces encryption, strong passcodes, and remote wipe capabilities.

2.4. Data and Cryptography Security

Data is classified into four tiers: Public, Internal, Confidential, and Strictly Confidential.

- Data at Rest: All databases and file servers storing Confidential or Strictly Confidential data utilize AES-256 encryption.
- Data in Transit: All internal and external API traffic is secured via HTTPS/TLS 1.3.
- Cryptographic keys are securely generated, stored, and rotated annually using an isolated Hardware Security Module (HSM).

Cybersecurity Resilience (NCA-ECC Subdomain 3-1 to 3-3) .3

3.1. Cybersecurity Incident Management

TechCorp maintains a 24/7 Security Operations Center (SOC). A formal Incident Response Plan (IRP) is established, detailing procedures for triage, containment, eradication, and recovery. In the event of a severe data breach, the CISO is mandated to report the incident to the NCA within the timeframe stipulated by national regulations (typically within 24 hours).

3.2. Business Continuity and Disaster Recovery

A comprehensive Disaster Recovery Plan (DRP) ensures the availability of critical services.

- Backups are performed daily, with weekly full backups stored in an immutable, offline, geographically separated facility within Saudi Arabia.
- The DRP is tested semi-annually through tabletop exercises and full failover simulations to ensure Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) are met.

Third-Party and Cloud Security (NCA-ECC Subdomain 4-1 to 4-2) .4

4.1. Vendor Risk Management

Prior to onboarding, all third-party vendors must undergo a rigorous cybersecurity risk assessment. Vendors handling TechCorp data must sign Non-Disclosure Agreements (NDAs) and contractually commit to adhering to NCA standards.

4.2. Cloud Computing Security

All cloud service providers utilized by TechCorp must be hosted within the Kingdom of Saudi Arabia to comply with data sovereignty regulations. Cloud environments are subject to continuous security posture management (CSPM) to detect misconfigurations.